

La misma clave, distintas garantías

Preservación de propiedades de seguridad en la migración de passkeys

[Nombre del autor] · [Afilación] · [correo electrónico]

NOTA DE ALCANCE. Este documento es un paper hipotético. Las implementaciones, mediciones y vulnerabilidades son inventadas, aunque técnicamente verosímiles. No deben citarse como hallazgos reales.

Resumen

Credential Exchange Format (CXF) y Credential Exchange Protocol (CXP) buscan permitir la transferencia segura de passkeys y otras credenciales entre credential providers. Aunque estos mecanismos protegen el transporte y estandarizan la representación de las credenciales, no está claro si una passkey conserva sus propiedades funcionales y de seguridad cuando cambia de custodio.

Presentamos el primer estudio sistemático hipotético sobre preservación semántica en la migración de passkeys. Definimos un modelo de equivalencia en tres niveles: identidad criptográfica, equivalencia funcional y equivalencia de seguridad. Desarrollamos PasskeyTransit, un framework de differential testing que genera credenciales sintéticas, ejecuta migraciones y verifica credenciales importadas mediante ceremonias WebAuthn y extensiones como PRF, hmac-secret, largeBlob y credBlob.

Evaluamos cinco implementaciones mediante 1.248 credenciales sintéticas y 18.720 rutas de migración. Aunque el 98,1 % de las credenciales importadas conservó la capacidad básica de autenticación, sólo el 72,6 % preservó todas las propiedades funcionales aplicables. Encontramos 43 divergencias, incluyendo pérdida silenciosa de extensiones, importaciones no idempotentes, degradaciones durante downgrades y resultados PRF inconsistentes después de migraciones múltiples.

Palabras clave: passkeys, WebAuthn, CXF, CXP, credential providers, differential testing, interoperabilidad.

1. Introducción

Las passkeys utilizan criptografía de clave pública para reemplazar contraseñas y proporcionar autenticación resistente al phishing. En WebAuthn, el relying party almacena una clave pública mientras la clave privada permanece bajo el control de un authenticator o credential provider.

La expansión de passkeys sincronizadas introdujo un problema de portabilidad. Una persona que cambia de password manager o ecosistema necesita transferir sus credenciales sin exportar claves privadas mediante archivos de texto inseguros y sin registrar manualmente una passkey nueva en cada servicio.

FIDO Alliance desarrolló CXF, que define la representación de credenciales transferidas, y CXP, que define un protocolo de intercambio protegido entre proveedores. Sin embargo, la confidencialidad del transporte responde sólo una parte del problema. Una passkey importada puede generar firmas válidas y aun así perder resultados PRF, blobs asociados, soporte para pagos, restricciones operacionales o información de custodia.

Pregunta central: ¿qué significa que una passkey siga siendo «la misma» después de cambiar de credential provider? Distinguimos equivalencia criptográfica, funcional y de seguridad.

1.1 Contribuciones

- Modelo de preservación de propiedades para passkeys migradas.
- Concepto de credential clone set para representar custodios capaces de utilizar una misma clave.

- PasskeyTransit, framework para generar, migrar y ejecutar passkeys sintéticas.
- Corpus de 1.248 credenciales con algoritmos, extensiones y condiciones adversariales.
- Evaluación de cinco implementaciones mediante rutas directas, round trips y múltiples proveedores.
- Reglas para propiedades críticas, atomicidad, idempotencia y consentimiento informado.

2. Antecedentes

2.1 WebAuthn y passkeys

Durante el registro WebAuthn, un authenticator crea un par (skC, pkC). El relying party registra pkC; una assertion posterior demuestra posesión de skC mediante una firma sobre authenticatorData y el hash de clientDataJSON.

Además de la clave, una passkey incorpora credential ID, RP ID, user handle, atributos presentables, extensiones WebAuthn/CTAP y propiedades operacionales del proveedor.

2.2 Credential Exchange Format

CXF representa una passkey mediante credentialId, rpId, username, userDisplayName, userHandle, una clave privada PKCS#8 y extensiones FIDO2 opcionales. La clave debe producir la misma clave pública registrada originalmente. CXF contempla PRF/hmac-secret, credBlob, largeBlob y Secure Payment Confirmation.

La especificación excluye de la exportación passkeys cuyo signature counter sea distinto de cero. Los importadores deben establecerlo en cero y no incrementarlo, una decisión compatible con credenciales sincronizadas pero insuficiente para detectar copias.

2.3 Credential Exchange Protocol

CXP permite que un importador solicite credenciales indicando versión, algoritmos HPKE, formato de archivo, modo de respuesta, identidad declarada, tipos de credenciales y extensiones conocidas. El exportador construye una respuesta cifrada. El protocolo protege el intercambio, pero no cubre completamente amenazas introducidas por los propios proveedores ni la destrucción posterior de copias.

2.4 Conjunto de clones

Definimos $\text{CloneSet}(C, t)$ como el conjunto de custodios capaces de producir una assertion válida para C en el instante t . Una migración $A \rightarrow B$ puede transformar $\{A\}$ en $\{A, B\}$; por tanto, salvo eliminación o rotación, amplía el conjunto de entidades capaces de utilizar la credencial.

3. Modelo de preservación

Representamos una passkey como $C = (I, K, F, S)$, donde I contiene identidad y binding, K material criptográfico, F capacidades funcionales y S propiedades operacionales y de seguridad. Una migración M produce $C' = M(C, A, B)$.

3.1 Equivalencia criptográfica

C y C' son criptográficamente equivalentes cuando preservan clave pública, credential ID, RP ID y user handle, y una assertion producida por C' es aceptada por el registro original.

3.2 Equivalencia funcional

Existe equivalencia funcional cuando, además de la identidad criptográfica, toda operación soportada por ambos proveedores produce resultados equivalentes. Para PRF exigimos $\text{PRF}(C, s) = \text{PRF}(C', s)$ para cada salt de prueba; para blobs exigimos igualdad exacta.

3.3 Equivalencia de seguridad

Existe equivalencia de seguridad cuando se conserva la funcionalidad, no aparecen custodios no autorizados, las degradaciones se comunican, las restricciones críticas se respetan, la operación es atómica o recuperable y los retries no crean estados ambiguos.

3.4 Clases de degradación

Clase	Definición
Explícita	Informada y aceptada por el usuario.
Silenciosa	La importación finaliza sin indicar la pérdida.
Funcional	Desaparece una capacidad de la credencial.
Operacional	Cambia custodia, recuperación o exportabilidad.
Crítica	Puede permitir uso indebido o pérdida irreversible.
Transitoria/Persistente	Existe sólo durante el flujo o permanece después.

4. Preguntas de investigación

- RQ1. ¿Con qué frecuencia se preserva la identidad criptográfica?
- RQ2. ¿Qué propiedades funcionales se pierden en rutas directas y de múltiples saltos?

- RQ3. ¿Cómo se manejan extensiones desconocidas, downgrades, duplicados y fallos parciales?
- RQ4. ¿Puede el usuario o el relying party observar la evolución del conjunto de custodios?

5. PasskeyTransit

5.1 Arquitectura

PasskeyTransit combina un generador de credenciales, un relying party local, adaptadores de proveedores, un mutador estructural y semántico, y oráculos independientes. El ground truth almacena claves, IDs, resultados PRF, blobs y propiedades esperadas.

5.2 Proveedores

Proveedor	Perfil
P1	Referencia estricta; rechaza degradaciones críticas.
P2	Referencia permisiva; conserva lo que puede.
P3	Legacy; sólo identidad básica.
P4	Prototipo independiente en Rust.
P5	Prototipo integrado con una API de plataforma.

5.3 Mutaciones y oráculos

El mutador elimina, duplica o altera campos; trunca base64url y PKCS#8; cambia RP IDs; introduce extensiones desconocidas, versiones futuras y estructuras profundas. Los oráculos verifican conformidad, correspondencia de claves, assertions WebAuthn, equivalencia de extensiones y divergencia semántica.

5.4 Rutas

Ejecutamos rutas $A \rightarrow B$, $A \rightarrow B \rightarrow A$, $A \rightarrow B \rightarrow C$ y $A \rightarrow B \rightarrow C \rightarrow A$. Repetimos importaciones idénticas para evaluar idempotencia y modificamos metadata entre reintentos.

6. Metodología experimental

6.1 Corpus

Categoría	N
Básicas ES256	240
PRF	208
hmac-secret	160
largeBlob	160
credBlob	160
Payments	80
Múltiples extensiones	120
Extensiones desconocidas	120
Total	1248

El corpus varía credential IDs, RP IDs, user handles, nombres, tamaños, duplicados y campos opcionales. Todas las credenciales son sintéticas y reproducibles a partir de semillas.

6.2 Ejecuciones y fallos

Ejecutamos 18.720 rutas: 6.240 migraciones directas, 6.240 round trips y 6.240 rutas de tres o más proveedores. Inyectamos fallos después de la aprobación, creación del payload, descifrado, primera persistencia y antes del commit.

6.3 Clasificación

Cada divergencia fue clasificada como permitida, ambigua, degradación visible, degradación silenciosa, violación normativa o violación de seguridad. El acuerdo interevaluador hipotético fue $\kappa=0,84$.

7. Resultados

7.1 Preservación criptográfica

El 98,1 % de las credenciales importadas conservó la identidad criptográfica completa. En 61 casos el importador aceptó el documento, pero la credencial resultante no produjo una assertion válida.

Resultado	%
Identidad preservada	98,1
Rechazo correcto	1,2
Importada, no autenticable	0,5
Asociación incorrecta	0,2

Las causas fueron clave no persistida (22), normalización incorrecta del credential ID (17), asociación a RP ID incorrecto (8) y reemplazo ambiguo (14). Los casos de RP ID incorrecto aparecieron sólo con inputs mutados inválidos.

7.2 Preservación funcional

Sólo el 72,6 % mantuvo todas las propiedades funcionales aplicables. Probar únicamente un login posterior no detectó la mayoría de degradaciones.

Propiedad	Preservación
Autenticación básica	98,1 %
User verification	96,8 %
PRF	81,4 %
hmac-secret	79,7 %
credBlob	89,1 %
largeBlob	83,6 %
Payments	68,3 %

En migraciones directas compatibles, PRF se conservó en el 96,9 %. En rutas de tres proveedores descendió al 81,4 %. El proveedor legacy ignoró material PRF; al reexportar, la pérdida resultó irreversible.

Ruta	Preservación total
A→B	88,7 %
A→B→A	84,2 %
A→B→C	76,9 %
A→B→C→A	69,8 %

7.3 Extensiones, downgrade e idempotencia

De 2.400 casos con extensiones desconocidas, el 31 % fue preservado como datos opacos, el 27 % rechazado y el 42 % descartado. Sólo el 18 % de los descartes produjo una advertencia visible.

El 14,8 % de los downgrades aceptados perdió alguna propiedad funcional; en el 9,3 % la pérdida fue silenciosa. Dos implementaciones deduplicaron correctamente, una actualizó metadata, una creó duplicados visibles y otra dependió del orden.

7.4 Fallos parciales

Resultado	%
Atómica	74,1
Parcial recuperable	18,6
Duplicados tras retry	5,9
Limpieza manual	1,4

No observamos claves sin cifrar en filesystem, pero dos implementaciones registraron credential IDs y RP IDs completos en logs de diagnóstico.

7.5 Evolución del clone set

Después de migrar, el proveedor de origen siguió autenticando en el 100 % de los casos; el destino, en el 98,1 %. Eliminar en un proveedor no afectó al otro, y restaurar un backup del origen recuperó copias eliminadas. Operacionalmente, la migración se comportó como clonación, no como transferencia exclusiva.

7.6 Resumen

Categoría	N
Pérdida silenciosa de extensiones	14
Importación no idempotente	8
Downgrade ambiguo	7
PRF inconsistente	5
Fallos parciales	4
Metadata sensible en logs	3
Confusión entre cuentas	2
Total	43

8. Casos representativos

8.1 Login correcto, PRF incorrecto

Una passkey conservó la firma WebAuthn, pero después de pasar por P3 y P4 produjo un resultado PRF diferente para el mismo salt. Una aplicación que usara PRF para cifrado perdería acceso a sus datos aunque el login siguiera funcionando.

8.2 Extensión futura descartada

P2 omitió una extensión desconocida y reexportó una passkey sintácticamente válida sin ella. En P1→P2→P1, origen y destino

final soportaban la propiedad, pero el intermediario destruyó la información.

8.3 Retry con duplicados

P5 persistió la credencial y falló antes del acknowledgement. El retry creó otra entrada con la misma clave y credential ID, pero diferente item ID interno, impidiendo al usuario identificar el resultado original.

8.4 Confusión visual

Dos credenciales con nombres Unicode visualmente similares fueron agrupadas pese a tener user handles distintos. WebAuthn permaneció seguro, pero la UI dificultó seleccionar la cuenta correcta.

9. Discusión

9.1 Misma clave no implica misma garantía

La equivalencia criptográfica no implica equivalencia funcional, y ésta tampoco implica equivalencia de seguridad. Un importador puede preservar la clave y al mismo tiempo perder extensiones, ampliar custodios, degradar recuperación o crear estados ambiguos.

9.2 Criticidad de extensiones

Clase	Respuesta recomendada
Informativa	Puede descartarse.
Funcional	Advertir antes de descartar.
Disponibilidad crítica	Rechazar o requerir aceptación.
Seguridad crítica	Abortar migración.
Identidad crítica	No transformar.

9.3 Manifest de propiedades

Proponemos que el exportador declare propiedades requeridas y opcionales, semántica de custodia y política de downgrade; el importador respondería qué preservó, descartó o no puede verificar. El usuario aprobaría la diferencia antes del commit.

9.4 Atomicidad

La secuencia recomendada es prepare → validate all → persist atomically → verify usability → commit. Cuando no sea posible, el resultado debe reportarse por credencial como imported, rejected, degraded, rolled-back o unknown.

9.5 Migración frente a rotación

Copiar la misma clave evita cambios en los relying parties, pero conserva el riesgo de copias previas. Una alternativa es autenticar con la credencial importada, registrar una nueva passkey, verificarla y revocar la antigua: una rotación asistida con una frontera de custodia más clara.

10. Recomendaciones

10.1 Para CXF/CXP

- Definir semántica explícita de copy, transfer y backup.
- Permitir que las extensiones declaren criticidad.
- Añadir un manifest de propiedades requeridas.

- Prohibir degradaciones silenciosas de propiedades críticas.
- Definir idempotency keys, resultados parciales y reglas de downgrade.
- Vincular el consentimiento con el conjunto exacto exportado.
- Emitir un receipt verificable de migración y custodia.

10.2 Para credential providers

- Verificar la clave antes de persistir y ejecutar una prueba WebAuthn posterior.
- Verificar PRF y extensiones cuando sea posible.
- Informar propiedades no soportadas y hacer la importación idempotente.
- Evitar logs con RP IDs, credential IDs o secretos.
- Diferenciar copy de transfer y mostrar si puede reexportarse.

10.3 Para relying parties

- Permitir múltiples passkeys y ofrecer revocación clara.
- Mostrar fecha de último uso y facilitar rotación.
- No depender de signature counters para passkeys sincronizadas.
- Adoptar señales de gestión cuando estén disponibles.

11. Limitaciones

El estudio evalúa sólo cinco implementaciones y utiliza credenciales sintéticas. Algunas propiedades de custodia no son observables: no podemos demostrar que un proveedor eliminó todas sus copias o backups. CXF/CXP continúan evolucionando y no realizamos un estudio formal con participantes. Sobre todo, los resultados cuantitativos de este borrador son ficticios y sólo ilustran cómo podría presentarse una evaluación real.

12. Consideraciones éticas

Las pruebas reales deberían usar únicamente cuentas controladas, dispositivos propios y entornos autorizados. Los defectos deben comunicarse mediante responsable disclosure. Los artifacts públicos deberían incluir semillas y generadores, no claves privadas de pruebas reales.

13. Trabajo futuro

- Análisis formal de CXP y vinculación entre consentimiento, importador y payload.
- Privacidad estructural frente a orchestrators.
- Migración asistida por rotación en relying parties.
- Receipts verificables de custodia y degradación.
- Estudios de usabilidad sobre copy, transfer, backup y revocación.

14. Conclusión

La migración de passkeys no es sólo un problema de transporte seguro. Una credencial puede conservar clave, credential ID, RP ID y capacidad de autenticarse, pero perder funcionalidades o cambiar sus garantías operacionales.

La propiedad relevante es que las propiedades requeridas de C estén incluidas entre las propiedades preservadas por M(C). La interoperabilidad sintáctica debe complementarse con mecanismos que hagan explícitas las propiedades preservadas, degradadas y no verificables.

Migrar de forma segura consiste en preservar —o renegociar conscientemente— las garantías asociadas a la clave.

Referencias

- [1] FIDO Alliance. Credential Exchange Specifications.
<https://fidoalliance.org/download-credential-exchange-specifications/>
- [2] Apple. What's New in Passkeys. WWDC 2025.
<https://developer.apple.com/videos/play/wwdc2025/279/>
- [3] FIDO Alliance. Credential Exchange Format 1.0.
<https://fidoalliance.org/specs/cx/cxf-v1.0-rd-20250313.html>
- [4] FIDO Alliance. Credential Exchange Protocol.
<https://fidoalliance.org/specs/cx/cxp-v1.0-wd-20241003.html>
- [5] W3C. Web Authentication: An API for Accessing Public Key Credentials, Level 3. <https://www.w3.org/TR/webauthn-3/>
- [6] IETF. RFC 9180: Hybrid Public Key Encryption. <https://www.rfc-editor.org/rfc/rfc9180>
- [7] Apple. ASCredentialImportManager.
<https://developer.apple.com/documentation/authenticationservices/ascredentialimportmanager>
- [8] Google. Credential Manager.
<https://developer.android.com/identity/credential-manager>